

Security Assessment Report

Target	http://juice-shop:3000
Date	2026-10-07 16:32 UTC
Tools run	nmap, zap, nuclei, nikto
Scope notes	Full baseline check, including web server checks.
Permission	Confirmed by Mohan Vishe at 2026-10-07T16:24:51+00:00
Scan ID	7390efd348b84a518a30c3a987237130

This is an automated, detection-only check. The findings come from open-source scanners and have not been confirmed by a person or by exploiting them, so some may be false alarms and real problems may be missing. It does not replace a manual penetration test.

1. Summary

Critical	High	Medium	Low	Info
0	0	5	9	19

The scan reported five medium-severity issues on the Juice Shop application. The most critical problems are missing security headers (clickjacking protection and CSP), a cross-domain configuration that may allow unwanted access, session identifiers being exposed in URLs, and an openly accessible Prometheus metrics endpoint. Addressing these will significantly improve the app's defense against common web attacks. Start by adding the required security headers, then fix the CORS settings, remove session IDs from URLs, and finally restrict the metrics endpoint.

2. Fix these first

1. Add the missing security headers, including X-Frame-Options to prevent clickjacking and a strict Content-Security-Policy.

Related findings: ZAP-10020-1, ZAP-10038-1

2. Review and tighten the cross-origin (CORS) configuration to allow only trusted origins.

Related findings: ZAP-10098

3. Eliminate session identifiers from URL rewrites and use cookies with the HttpOnly and Secure flags instead.

Related findings: ZAP-3-1

4. Secure the Prometheus metrics endpoint by restricting access to authorized users or internal networks only.

Related findings: NUCLEI-prometheus-metrics

Written by the Reporter agent from the findings below.

3. What ran

nmap: Initial network service discovery.

zap: Passive spidering and baseline security header check.

nuclei: Template-based technology and misconfiguration detection.

nikto: Web server specific checks as requested.

Tool	What it checks	Result	Time	Findings
nmap	TCP connect scan of the 100 most common ports with service/version detection. Shows which network services the host exposes.	ok	11.7 s	1
zap	Spiders the web app for about a minute and runs ZAP's passive rules on every response: missing security headers, cookie flags, information leaks. No active attacks, no form submissions.	ok	59.3 s	9
nuclei	Runs community detection templates for technologies, misconfigurations, exposed files and exposed admin panels. Intrusive, brute-force and DoS templates are excluded.	ok	164.6 s	13
nikto	Checks the web server for leftover files, outdated software banners and common misconfigurations. Detection test classes only. Noisy and optional; time-boxed to two and a half minutes.	timeout	151.1 s	10

Note: nikto: Stopped at the 150s time box; results are partial.

4. What was not tested

- Active attack testing: no injection payloads are sent, so SQL injection, XSS and similar flaws are not probed
- Login, session and access-control logic (who can see or change what)
- Business logic flaws (prices, coupons, workflows)
- Pages behind a login form, unless HTTP Basic credentials were supplied
- Manual verification: every finding is a scanner result that still needs confirming

5. Findings

1. **[Medium]** Prometheus Metrics - Detect

NUCLEI-prometheus-metrics · nuclei · CVSS 5.3 · CVSS score 5.3 reported by nuclei · CWE-200

Where: <http://juice-shop:3000/metrics> (seen 1x)

Prometheus metrics page was detected.

Evidence from nuclei: Template matched at <http://juice-shop:3000/metrics>

How to fix (AI-written): Restrict the /metrics endpoint to trusted IPs or require authentication, and consider disabling it in production if not needed.

2. [Medium] Missing Anti-clickjacking Header

ZAP-10020-1 · zap · zap rated it 'medium'; mapped to the matching CVSS band · CWE-1021

Where: `http://juice-shop:3000/socket.io/?EIO=4&transport=polling&t=Q4NBv8L&sid=nM538MaZd_pm-mkxAAAA` (seen 2x)

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Evidence from zap: `x-frame-options`

How to fix (from zap): Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.

If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

How to fix (AI-written): Configure the web server to send an X-Frame-Options header (e.g., SAMEORIGIN or DENY) on all responses to block clickjacking attacks.

3. [Medium] Content Security Policy (CSP) Header Not Set

ZAP-10038-1 · zap · zap rated it 'medium'; mapped to the matching CVSS band · CWE-693

Where: `http://juice-shop:3000` (seen 54x)

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

How to fix (from zap): Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

How to fix (AI-written): Define a Content-Security-Policy header that limits sources for scripts, styles, and other resources, and apply it globally.

4. [Medium] Cross-Domain Misconfiguration

ZAP-10098 · zap · zap rated it 'medium'; mapped to the matching CVSS band · CWE-264

Where: `http://juice-shop:3000/assets/public/favicon.js.ico` (seen 100x)

Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.

Evidence from zap: `Access-Control-Allow-Origin: *`

How to fix (from zap): Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance).

Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

How to fix (AI-written): Audit the CORS policy; ensure Access-Control-Allow-Origin is set only to required origins and avoid using a wildcard.

5. **[Medium]** Session ID in URL Rewrite

ZAP-3-1 · zap · zap rated it 'medium'; mapped to the matching CVSS band · CWE-598

Where: http://juice-shop:3000/socket.io/?EI0=4&transport=polling&t=Q4NBv8L&sid=nm538MaZd_pm-mkxAAAA (seen 16x)

URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history or server logs.

Evidence from zap: nm538MaZd_pm-mkxAAAA

How to fix (from zap): For secure content, put session ID in a cookie. To be even more secure consider using a combination of cookie and URL rewrite.

How to fix (AI-written): Remove session IDs from URL parameters or rewrites; store session data in secure, HttpOnly cookies instead.

6. **[Low]** Retrieved access-control-allow-origin header: *.

NIKTO-000287 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/ (seen 1x)

Retrieved access-control-allow-origin header: *.

Evidence from nikto: GET /

7. **[Low]** /ftp/: This might be interesting.

NIKTO-001675 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/ftp/ (seen 1x)

This might be interesting.

Evidence from nikto: GET /ftp/

8. **[Low]** Suggested security header missing: permissions-policy.

NIKTO-013587 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/ (seen 1x)

Suggested security header missing: permissions-policy.

Evidence from nikto: GET /

9. **[Low]** Uncommon header(s) 'x-recruiting' found, with contents: ##/jobs.

NIKTO-999100 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/ (seen 1x)

Uncommon header(s) 'x-recruiting' found, with contents: ##/jobs.

Evidence from nikto: GET /

10. [Low] /robots.txt: contains 1 entry which should be manually viewed.

NIKTO-999996 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/robots.txt (seen 1x)

contains 1 entry which should be manually viewed.

Evidence from nikto: GET /robots.txt

11. [Low] /ftp:/robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200).

NIKTO-999997 · nikto · nikto does not rate findings; listed as Low by default

Where: juice-shop:3000/ftp/ (seen 1x)

/robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200).

Evidence from nikto: GET /ftp/

12. [Low] X-Content-Type-Options Header Missing

ZAP-10021 · zap · zap rated it 'low'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000/socket.io/?EI0=4&transport=polling&t=Q4NBv5T (seen 4x)

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

Evidence from zap: x-content-type-options

How to fix (from zap): Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

13. [Low] Timestamp Disclosure - Unix

ZAP-10096 · zap · zap rated it 'low'; mapped to the matching CVSS band · CWE-497

Where: http://juice-shop:3000/sitemap.xml (seen 102x)

A timestamp was disclosed by the application/web server. - Unix

Evidence from zap: 1666666667

How to fix (from zap): Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

14. **[Low] Private IP Disclosure**

ZAP-2 · zap · zap rated it 'low'; mapped to the matching CVSS band · CWE-497

Where: `http://juice-shop:3000/rest/admin/application-configuration` (seen 1x)

A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.

Evidence from zap: `192.168.99.100:3000`

How to fix (from zap): Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.

15. **[Info] /public/: This might be interesting.**

NIKTO-001811 · nikto · nikto flagged this address, but the site returns the same page for any address: likely a false alarm

Where: `juice-shop:3000/public/` (seen 1x)

This might be interesting. Checked: this address returns the same page as a made-up address, so the file is probably not really there.

Evidence from nikto: `GET /public/`

16. **[Info] /.htpasswd: Contains authorization information.**

NIKTO-002739 · nikto · nikto flagged this address, but the site returns the same page for any address: likely a false alarm

Where: `juice-shop:3000/.htpasswd` (seen 1x)

Contains authorization information. Checked: this address returns the same page as a made-up address, so the file is probably not really there.

Evidence from nikto: `GET /.htpasswd`

17. **[Info] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.**

NIKTO-002743 · nikto · nikto flagged this address, but the site returns the same page for any address: likely a false alarm

Where: `juice-shop:3000/.bash_history` (seen 1x)

A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web. Checked: this address returns the same page as a made-up address, so the file is probably not really there.

Evidence from nikto: `GET /.bash_history`

18. **[Info] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.**

NIKTO-002756 · nikto · nikto flagged this address, but the site returns the same page for any address: likely a false alarm

Where: `juice-shop:3000/.sh_history` (seen 1x)

A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web. Checked: this address returns the same page as a made-up address, so the file is probably not really there.

Evidence from nikto: `GET /.sh_history`

19. [\[Info\]](#) Open port 3000/tcp (ppp?)

NMAP-3000-tcp · nmap · open port, reported for information

Where: 172.19.0.4:3000 (seen 1x)

Port 3000/tcp is open. nmap could not fingerprint the service; 'ppp' is its default guess for this port number.

Evidence from nmap: 3000/tcp open ppp?

20. [\[Info\]](#) FingerprintHub Technology Fingerprint (qm-system)

NUCLEI-fingerprinthub-web-fingerprints:qm-system · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-200

Where: http://juice-shop:3000 (seen 1x)

FingerprintHub Technology Fingerprint tests run in nuclei.

Evidence from nuclei: Template matched at http://juice-shop:3000

21. [\[Info\]](#) HTTP Missing Security Headers (content-security-policy)

NUCLEI-http-missing-security-headers:content-security-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (seen 1x)

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence from nuclei: Template matched at http://juice-shop:3000

22. [\[Info\]](#) HTTP Missing Security Headers (cross-origin-embedder-policy)

NUCLEI-http-missing-security-headers:cross-origin-embedder-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (seen 1x)

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence from nuclei: Template matched at http://juice-shop:3000

23. [\[Info\]](#) HTTP Missing Security Headers (cross-origin-opener-policy)

NUCLEI-http-missing-security-headers:cross-origin-opener-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (seen 1x)

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence from nuclei: Template matched at http://juice-shop:3000

24. [\[Info\]](#) HTTP Missing Security Headers (cross-origin-resource-policy)

NUCLEI-http-missing-security-headers:cross-origin-resource-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (seen 1x)

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence from nuclei: Template matched at http://juice-shop:3000

25. [\[Info\]](#) HTTP Missing Security Headers (permissions-policy)

NUCLEI-http-missing-security-headers:permissions-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (seen 1x)

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence from nuclei: Template matched at http://juice-shop:3000

26. [\[Info\]](#) HTTP Missing Security Headers (referrer-policy)

NUCLEI-http-missing-security-headers:referrer-policy · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (seen 1x)

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence from nuclei: Template matched at http://juice-shop:3000

27. [\[Info\]](#) HTTP Missing Security Headers (strict-transport-security)

NUCLEI-http-missing-security-headers:strict-transport-security · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (seen 1x)

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence from nuclei: Template matched at http://juice-shop:3000

28. [\[Info\]](#) HTTP Missing Security Headers (x-permitted-cross-domain-policies)

NUCLEI-http-missing-security-headers:x-permitted-cross-domain-policies · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-693

Where: http://juice-shop:3000 (seen 1x)

This template searches for missing HTTP security headers. The impact of these missing headers can vary.

Evidence from nuclei: Template matched at http://juice-shop:3000

29. [\[Info\]](#) OWASP Juice Shop

NUCLEI-owasp-juice-shop-detect · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band

Where: http://juice-shop:3000 (seen 1x)

Evidence from nuclei: Template matched at http://juice-shop:3000

30. [\[Info\]](#) Public Swagger API - Detect

NUCLEI-swagger-api · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band · CWE-200

Where: http://juice-shop:3000/api-docs/swagger.yaml (seen 1x)

Public Swagger API was detected.

Evidence from nuclei: Template matched at http://juice-shop:3000/api-docs/swagger.yaml

31. [\[Info\]](#) Wappalyzer Technology Detection (google-font-api)

NUCLEI-tech-detect:google-font-api · nuclei · nuclei rated it 'info'; mapped to the matching CVSS band

Where: http://juice-shop:3000 (seen 1x)

Evidence from nuclei: Template matched at http://juice-shop:3000

32. [\[Info\]](#) Modern Web Application

ZAP-10109 · zap · zap rated it 'informational'; mapped to the matching CVSS band

Where: http://juice-shop:3000 (seen 44x)

The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.

Evidence from zap: <script>
window.addEventListener("load", function(){
window.cookieconsent.initialise({
"palette": {
"popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" },
"button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" }
},
"theme": "classic",
"position": "bottom-right",
"content": { "messa...

How to fix (from zap): This is an informational alert and so no changes are required.

33. [\[Info\]](#) Session Management Response Identified

ZAP-10112 · zap · zap rated it 'informational'; mapped to the matching CVSS band

Where: http://juice-shop:3000/rest/continue-code (seen 1x)

The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

Evidence from zap: continueCode

How to fix (from zap): This is an informational alert rather than a vulnerability and so there is nothing to fix.

6. Quality checks on this report

Automatic checks run by code after the agents finish. 1.0 is a full pass.

Check	Score	Detail
plan_followed	1.00	4 of 4 planned tools ran
stayed_in_scope	1.00	no tool ran outside the approved plan
tools_completed	1.00	4 of 4 tool runs finished without error
target_stayed_up	1.00	the target kept answering through every scan
findings_traceable	1.00	33 of 33 findings found again in the raw scanner output
ai_text_grounded	1.00	AI-written text refers only to findings and CVEs the scanners reported
fix_advice_coverage	1.00	5 of 5 findings rated Medium or above come with fix advice